SECCIÓN 6.3

Acciones iniciales: qué hacer, qué no y cuándo pedir autorización

Temas de esta sección:

- Acciones de análisis vs acciones de respuesta: la diferencia importa
- Acciones generalmente seguras (no modifican el entorno)
- Acciones que pueden afectar evidencia o disponibilidad
- Cuándo pedir autorización y cuándo actuar rápido
- Aislar, bloquear, deshabilitar: casos y consideraciones
- Cómo documentar acciones tomadas + ejercicio de clasificación

Antes de actuar, clasificar: ¿esta acción solo recopila información o modifica el entorno?

Acciones de ANÁLISIS

Solo recopilan información. No modifican el entorno.

- Revisar process tree y command line
- Consultar reputación del hash o dominio
- Exportar logs del SIEM
- Buscar el mismo indicador en otros hosts
- Documentar la línea temporal
- Validar si existe ticket o cambio
- Revisar actividad del usuario en identidad
- Consultar WAF o proxy logs

Generalmente seguras. No requieren autorización previa.

Acciones de RESPUESTA

Modifican el entorno. Pueden afectar disponibilidad.

- Aislar un endpoint o servidor
- Bloquear un dominio o IP en firewall
- Revocar sesiones o tokens de usuario
- Deshabilitar una cuenta
- Eliminar un archivo sospechoso
- Crear o modificar reglas de WAF
- Reiniciar un servicio o equipo
- Borrar una regla de correo maliciosa

Requieren contexto, autorización o coordinación previa.

Regla práctica: primero analizar para tener evidencia suficiente, luego responder con criterio y con las personas correctas involucradas.

6.3 | Clasificación de acciones: tres categorías

No todas las acciones tienen el mismo impacto. Clasificarlas antes de ejecutar:

A	GENERALMENTE SEGURAS No modifican el entorno. Ayudan a construir contexto.	• Revisar eventos previos y posteriores • Consultar reputación de hash/IP/dominio • Exportar logs relevantes • Buscar mismo indicador en otros hosts • Documentar línea temporal • Validar si existe ticket o cambio
B	REQUIEREN AUTORIZACIÓN / COORDINACIÓN Modifican el entorno, pueden afectar disponibilidad o cuentas críticas.	• Aislar un endpoint (si es crítico: coordinar) • Revocar sesiones de usuario comprometido • Bloquear dominio en firewall • Deshabilitar cuenta (de servicio: coordinar) • Cambiar reglas de firewall global • Escalar formalmente según severidad
C	NO RECOMENDADAS SIN PRESERVAR Pueden destruir información necesaria para la investigación.	• Eliminar archivo sospechoso • Borrar regla de correo sin registrar detalles • Reiniciar equipo antes de revisar procesos • Matar procesos sin capturar command line • Revocar tokens sin registrar IP/dispositivo

No siempre hay tiempo para un proceso largo. La regla: impacto operativo y criticidad del activo definen el umbral:

Situación	Acción	Consideración
Malware activo en endpoint de usuario sin impacto crítico	**El playbook permite aislar**	*Autorización del playbook*
Ransomware en curso cifrando servidor de archivos	**Aislar de inmediato**	*Notificar después. El impacto supera el riesgo de no actuar*
Web shell en servidor de pagos productivo	**Preservar y coordinar antes de actuar**	*IR + negocio + infra antes de cualquier cambio*
Cuenta ejecutiva con login anómalo y regla de correo	**Revocar sesión activa**	*Validar con identidad si es posible. Si no, actuar y documentar*
Bloquear dominio de phishing detectado por TI	**Bloquear con validación de impacto**	*Confirmar que no es CDN compartido o servicio legítimo*

Cuando se actúa antes de pedir autorización, documentar inmediatamente: qué se hizo, cuándo, por qué y quién fue notificado después.

6.3 | Aislar, bloquear y deshabilitar: cuándo y con qué cuidado

Las tres acciones de contención más comunes — y sus consideraciones:

AISLAR ENDPOINT	Malware activo, C2 probable, persistencia creada, ejecución permitida con actividad posterior • ¿El equipo es crítico o productivo? • ¿Hay ejecución activa en este momento? • ¿El playbook lo permite? • ¿Se preservó evidencia mínima?	*Aislar WEB-PAY-01 puede cortar pagos → requiere coordinación.*
BLOQUEAR DOMINIO/IP	C2 confirmado, dominio de phishing activo, infraestructura maliciosa conocida • ¿Es dominio dedicado o compartido (CDN, cloud)? • ¿El bloqueo es global o por segmento? • ¿Puede afectar apps legítimas? • ¿La reputación tiene fecha y contexto?	*Bloquear drive.google.com puede afectar muchos usuarios → no bloquear sin validar.*
DESHABILITAR CUENTA	Cuenta comprometida probable con actividad sensible posterior • ¿Es cuenta de usuario o de servicio? • ¿Hay integraciones dependientes? • ¿Se puede revocar sesión primero? • ¿Está coordinado con identidad?	*Deshabilitar svc_billing puede romper un proceso crítico → coordinar antes.*

6.3 | Documentar acciones + ejercicio de clasificación

Toda acción relevante debe quedar registrada con timestamp, descripción y quién la tomó:

```
10:05 - Se recibe alerta EDR: Suspicious PowerShell en FIN-LAP-022
10:08 - Se revisa process tree. WINWORD.EXE → powershell.exe -nop -w
hidden -enc
10:10 - Se registra hash SHA256 de update.exe
10:12 - Se identifica tarea programada: OneDriveUpdate →
C:\Users\Public\update.exe
10:14 - Se detecta conexión periódica cada 60s a billing-check-
update.net (Allowed)
10:16 - Se busca hash en otros endpoints: 2 hosts adicionales con
mismo indicador
10:20 - Se escala a IR con recomendación de aislamiento y revisión de
correo origen
10:25 - IR autoriza aislamiento de los 3 endpoints afectados
10:28 - Endpoints aislados desde consola EDR según playbook
```

Ejercicio: clasificá estas acciones en A, B o C:

Revisar process tree del endpoint afectado	A
Exportar logs del SIEM de las últimas 4 horas	A
Consultar reputación del hash en VirusTotal	A
Eliminar regla de correo sin registrar destino	C
Aislar un servidor de pagos productivo	B
Borrar el archivo sospechoso detectado	C
Bloquear dominio globalmente en firewall	B
Revocar sesión de cuenta comprometida posible	B